Governance-First Identity

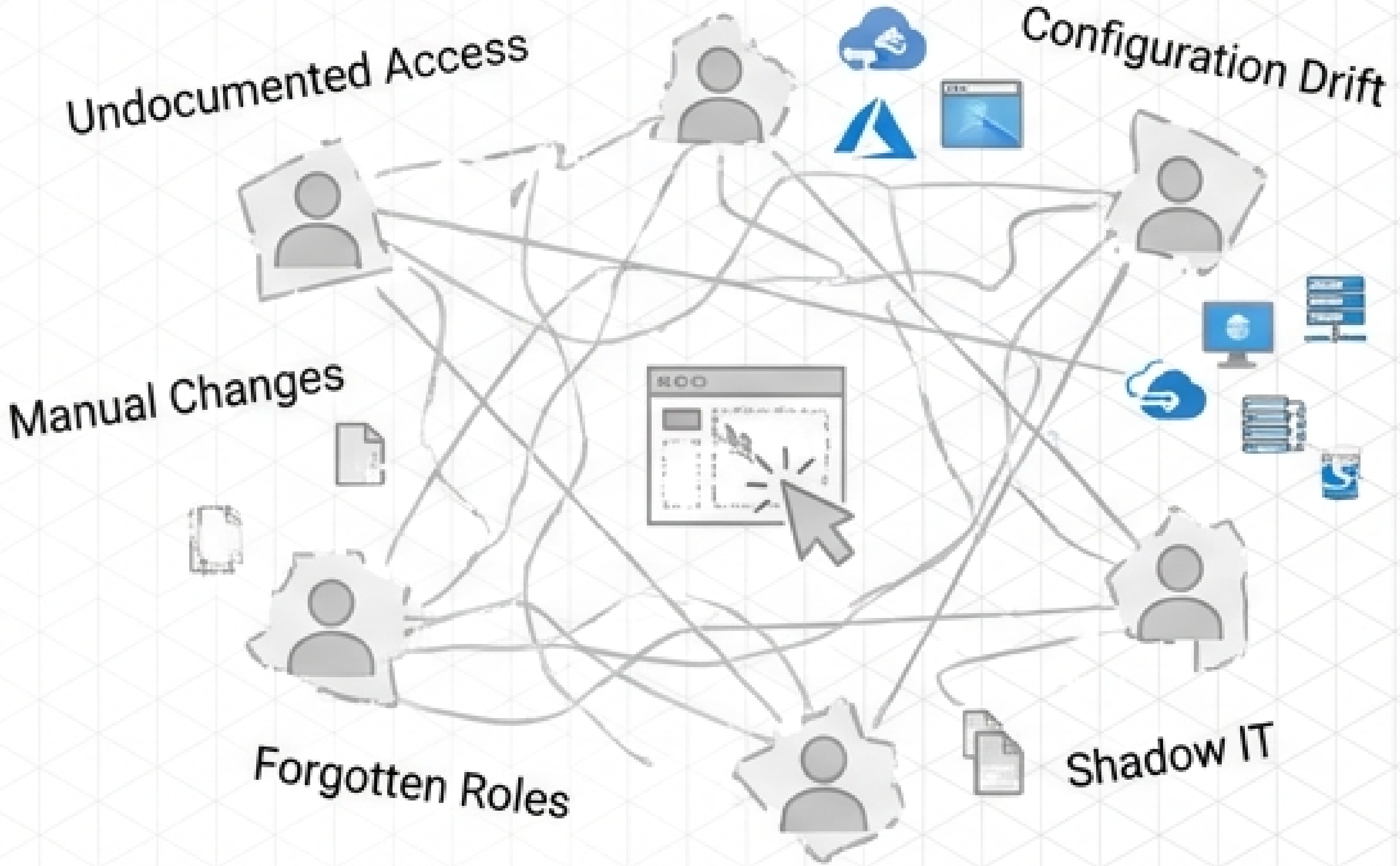
Orchestrating Zero-Trust Enterprise Access via YAML-Driven GitOps

Repository Blueprint: App-Users & App-Users-Config
Target Audience: Platform Engineering & IAM

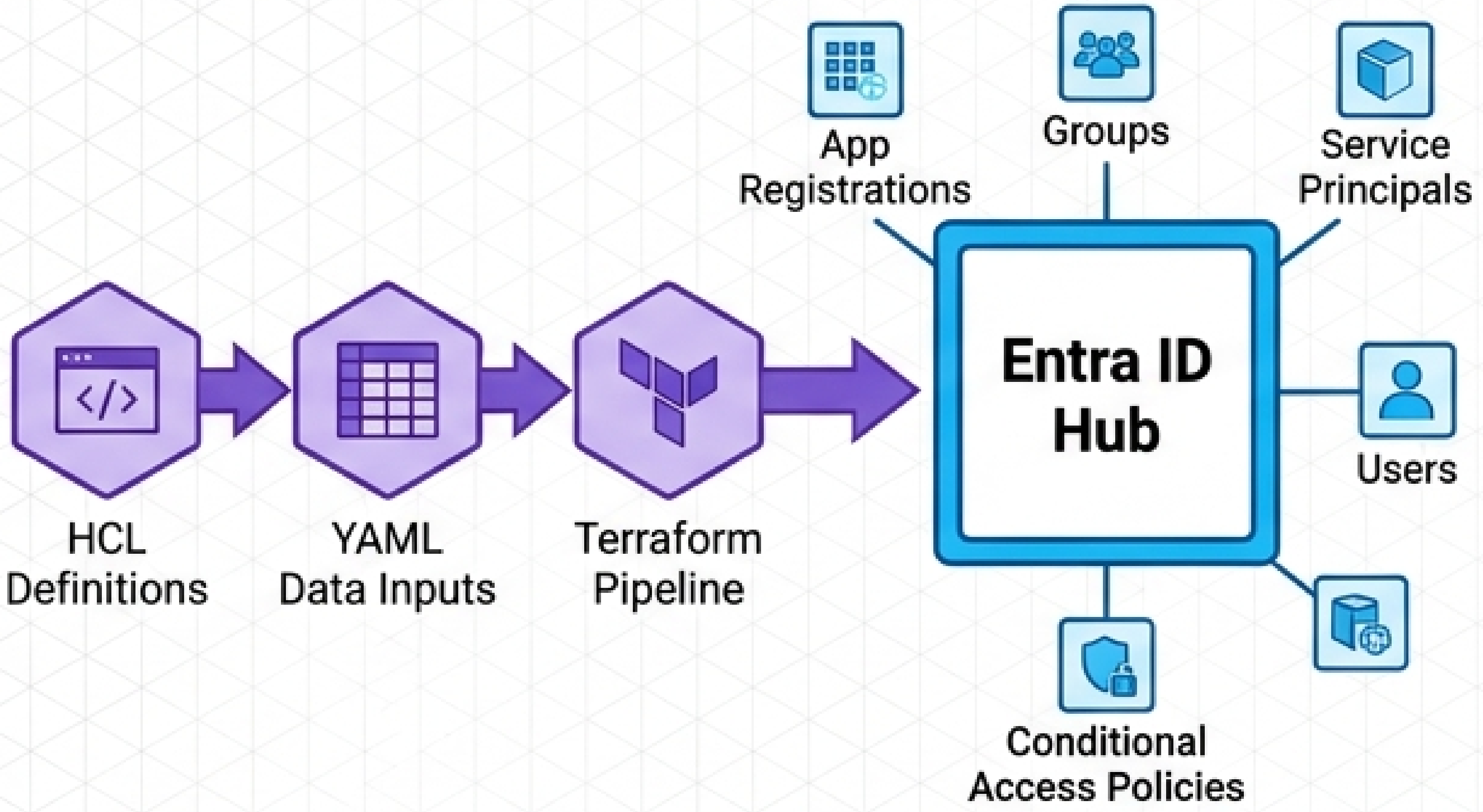
NotebookLM

Identity is Infrastructure. Infrastructure is Code.

The Manual Chaos (Click-Ops)



IaC Sovereignty



Zero-Trust Perimeters

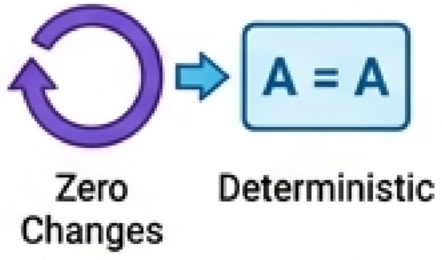
Eliminating trusted networks. Every interaction demands compound authentication, moving security from the perimeter to the identity.

IaC Sovereignty

100% of identity resources are defined in HCL and YAML. Manual Azure portal changes are flagged as drift and automatically destroyed.

Idempotent Execution

Running the pipeline with identical inputs guarantees zero changes, producing a mathematically deterministic identity state.



NotebookLM

The Dual-Repo Architecture: Logic vs. Data

The Engine: App-Users	The Fuel: App-Users-Config
Function: Terraform Logic & Azure DevOps Pipelines	**Function:** Identity Database & RBAC Declarations
Ownership: Platform Engineering & DevOps Teams	**Ownership:** Business, HR, & IAM Teams
Execution: Global CI/CD Orchestration & State Management	**Execution:** Pure Declarative Lists & Self-Service Pull Requests
Language: HCL (75.6%) & Shell Scripts	**Language:** YAML

Architectural Takeaway: By decoupling the logic engine from the data fuel, non-technical IAM administrators can securely manage enterprise access via simple YAML pull requests, entirely isolated from core infrastructure code.

NotebookLM

The Identity Archetype Matrix

Identity Configuration Root

Internal Users

30-internal-users-mainbranch.yaml

Required Keys

first-name	center
email	app-core-admin-role

Pipeline Behavior: Creates fully managed, native Entra ID identities and RBAC mapping.

External Users

50-external-users-mainbranch.yaml

Required Keys

email	center	env	roles

Pipeline Behavior: Triggers Azure AD B2B External Identities (Guest Invitations) for vendors/partners.

Manually Provisioned

70-internal-users-manually-provisioned-mainbranch.yaml

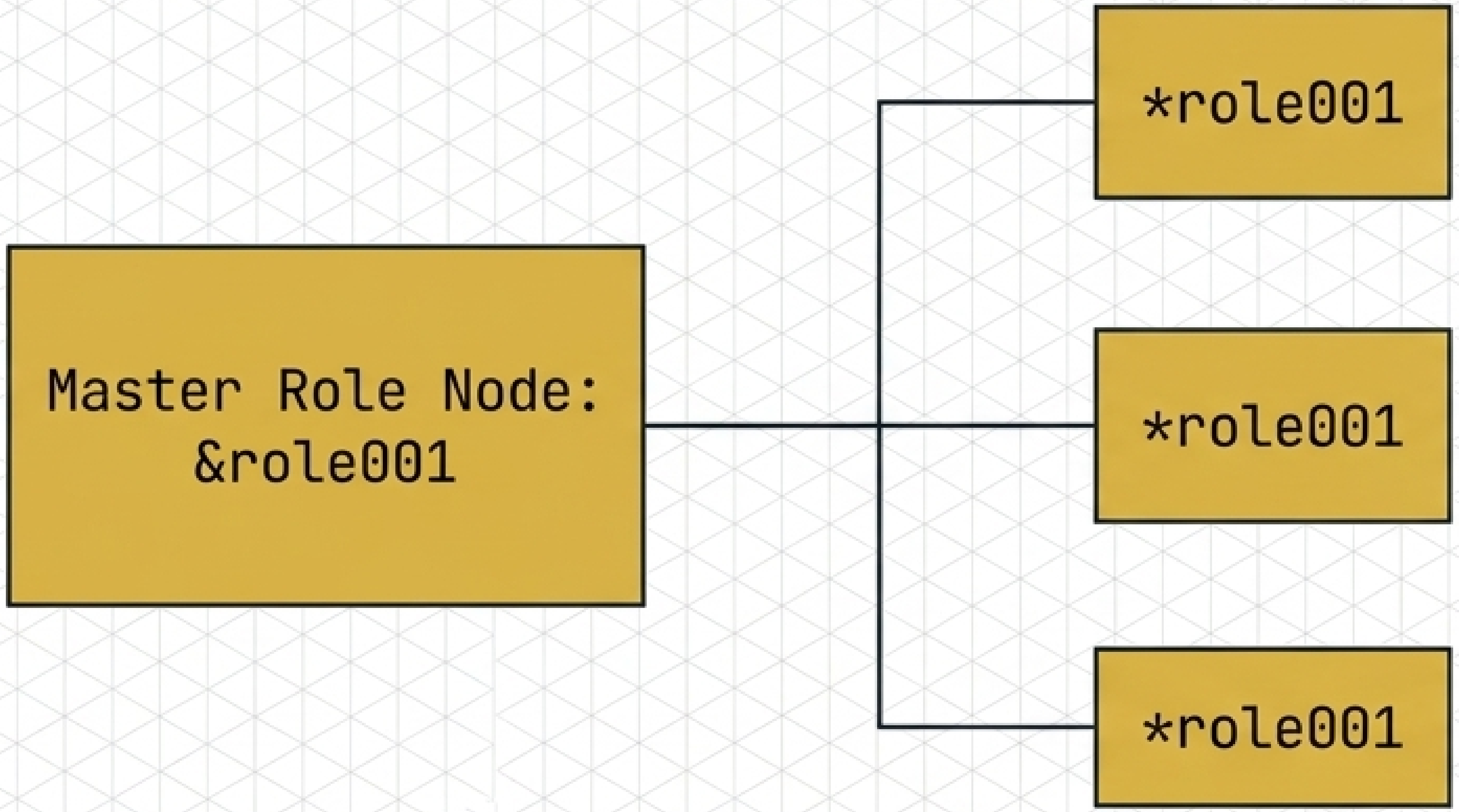
Required Keys

email	center	app-core-user-role

Pipeline Behavior: Manages RBAC and environment mapping for existing corporate employees without generating new accounts.

NotebookLM

DRY Identity: YAML Anchors and References



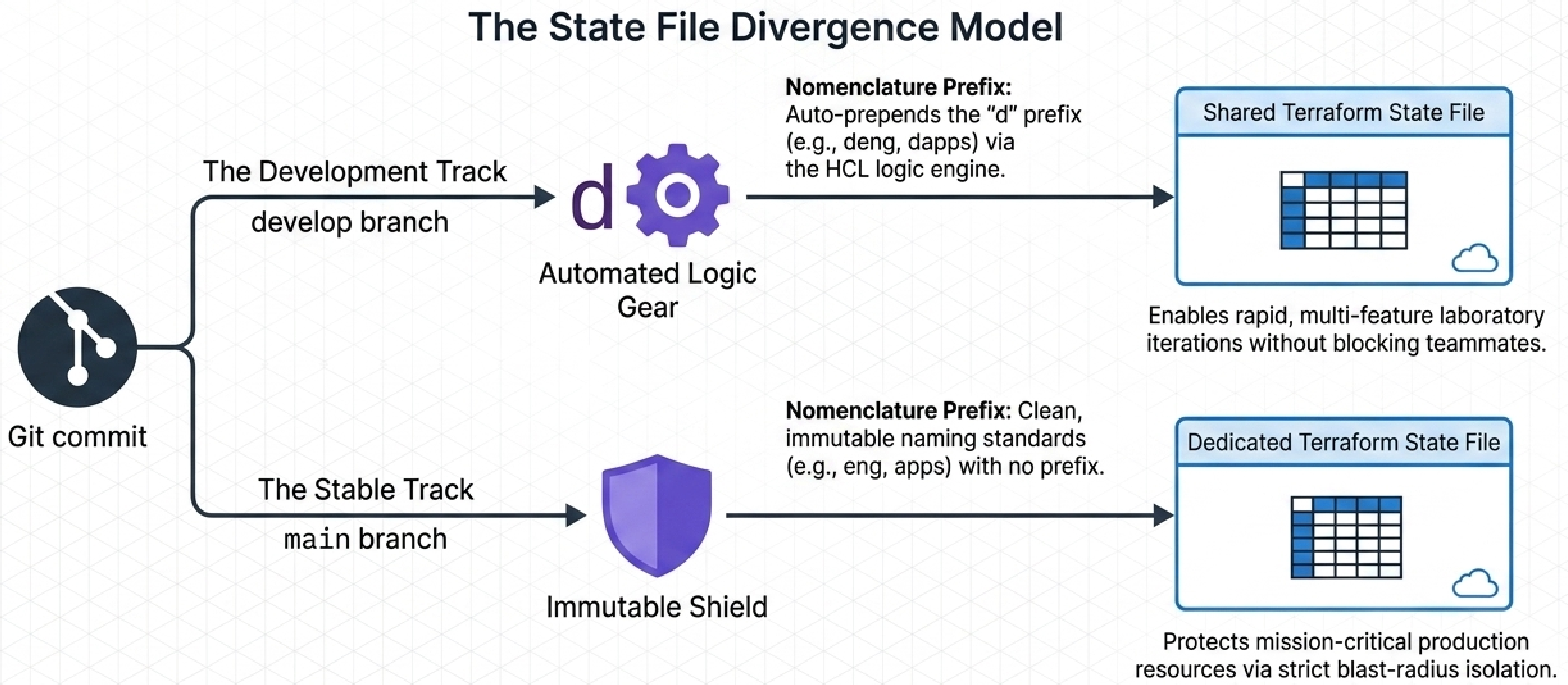

```yaml
app-core-admin-role: &role001
  - nedev
  - neqa
  - cusdev
```

```yaml
app-core-admin-role: *role001
```

Leveraging native YAML node anchors (&) and references (*) to enforce DRY (Don't Repeat Yourself) principles. Modifying a single master anchor instantly cascades role adjustments across dozens of downstream user profiles, completely eliminating copy-paste drift and human error.

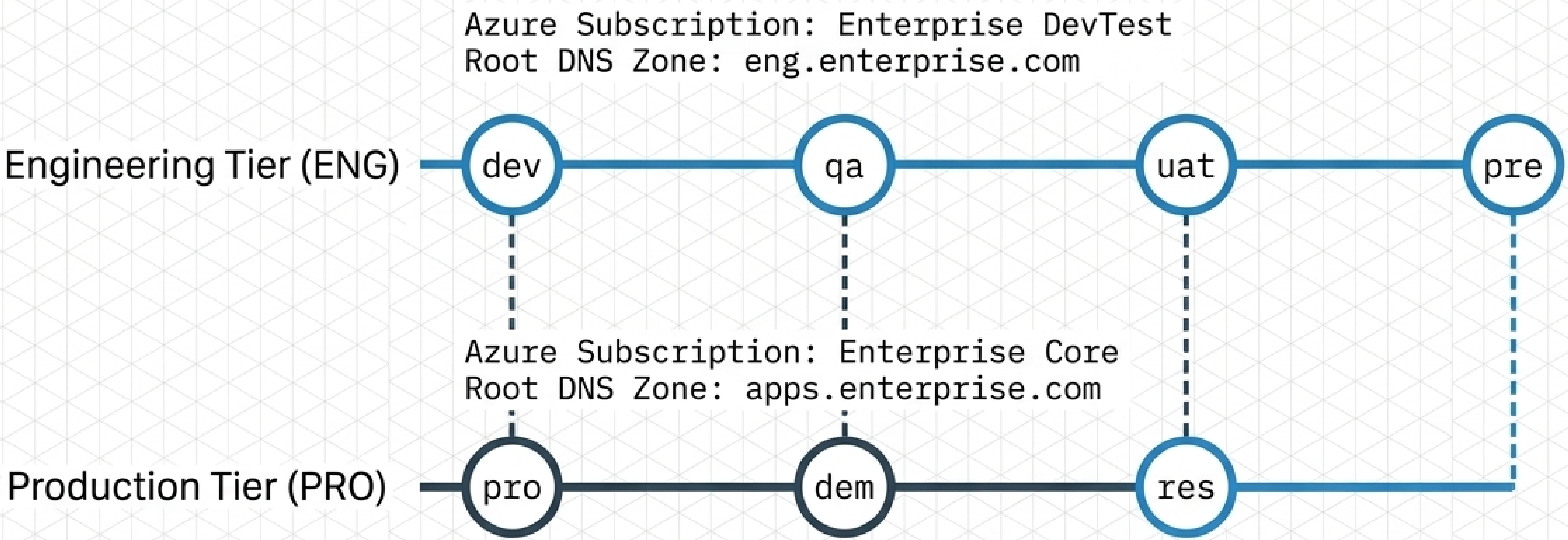
NotebookLM

Branch-Aware State Divergence



NotebookLM

Global Environment and Tier Parity Strategy



Strict Tier Parity ensures that Terraform code validated in the ENG tier behaves identically in the PRO tier. The logic remains exactly the same; environments differ exclusively in compute scale (e.g., Standard vs. Premium SKU) and financial isolation.

NotebookLM

The Sequential Provisioning Logic

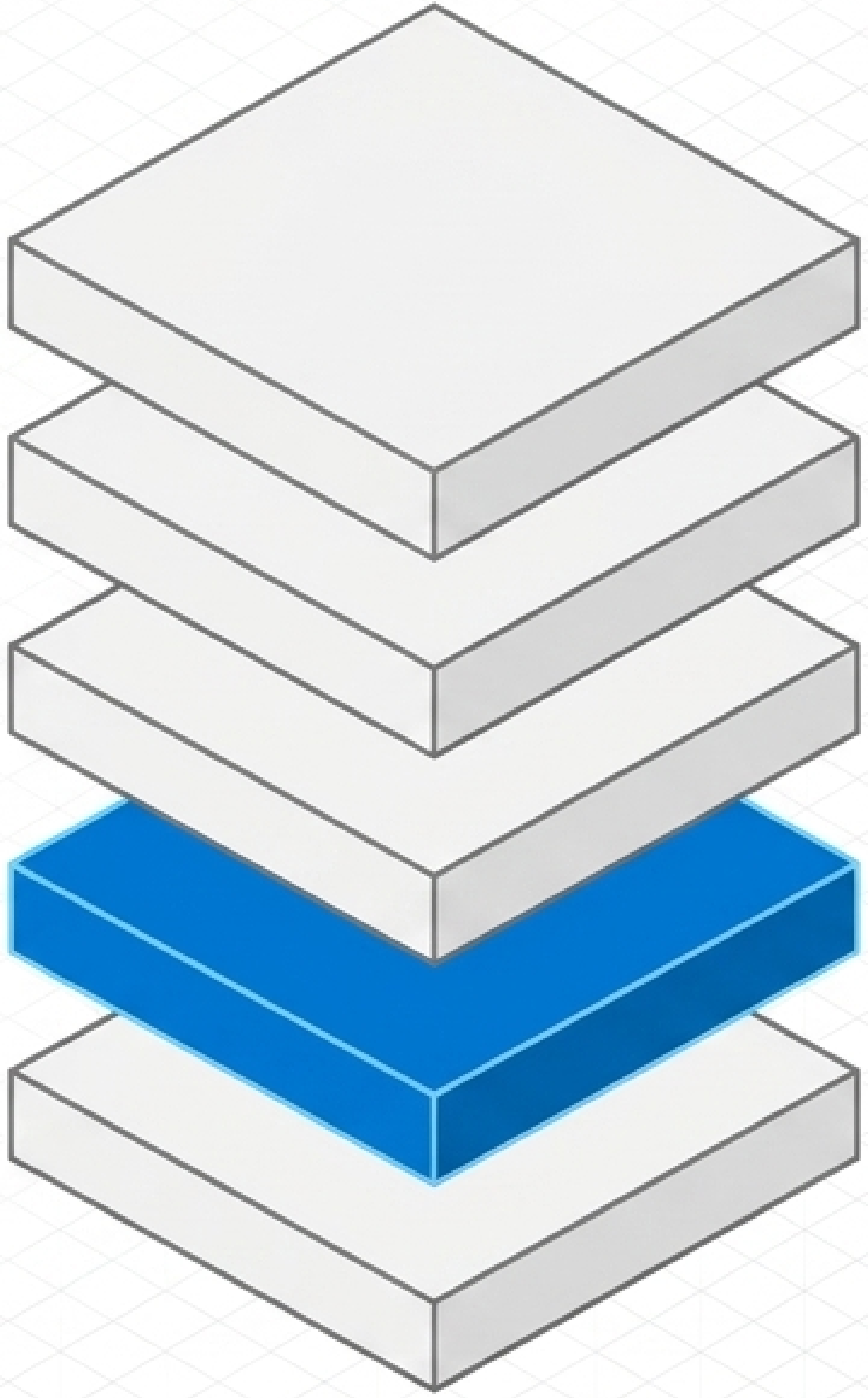
Layer 5: **Day2-Ops & AKS**
Monitoring, Compute Clusters, Metrics.

Layer 4: **App-Core**
Business Workloads, WAF, Backend APIs.

Layer 3: **App-Catalog**
Service Registry, Database Metadata.

Layer 2: **App-Users**
Identity Governance, Entra ID, Roles.

Layer 1: **Shared-Infra**
Foundation Backbone, VNet, Core DNS.



Dependency Protocol: Infrastructure executes strictly bottom-up.

Business compute `(App-Core)` cannot deploy until the `User Identities`, `Service Principals`, and RBAC security groups `(App-Users)` exist to secure them.

NotebookLM

DevOps Service Connection Topography

Service Principals (Keys)	Azure DevOps Pipelines (Tunnels)	Azure Target (Locks)
State Manager `sp-...-devops`	`svccon-app-core-users-devops`	Enterprise DevOps Subscription (TFSTATE Lock) Requires Owner rights.
DevTest Executor `sp-...-dev`	`svccon-app-core-users-dev`	Enterprise DevTest Subscription (DEV, QA, UAT, PRE) Requires Owner rights for RBAC assignment.
Core Executor `sp-...-pro`	`svccon-app-core-users-pro`	Enterprise Core Subscription (PRO, DEM, RES) Requires Owner rights.
Repo Reader `cloud-admin@example.com`	`svccon-app-core-users-yaml`	YAML Configuration Database Uses scoped PAT for “Code Read” only.

NotebookLM

Secretless CI/CD via Workload Identity (OIDC)

The Security Risk

Long-lived Service Principal secrets stored in repositories or pipeline variables act as a prime attack vector for infrastructure compromise.

The OIDC Trust Chain

Azure DevOps pipelines utilize `use_oidc = true` to trade a short-lived, **ephemeral token** for a scoped Azure access token. **Zero static credentials.**

Trust Subject Pattern:

```
sc://{organization}/{project}/{service_connection}
```

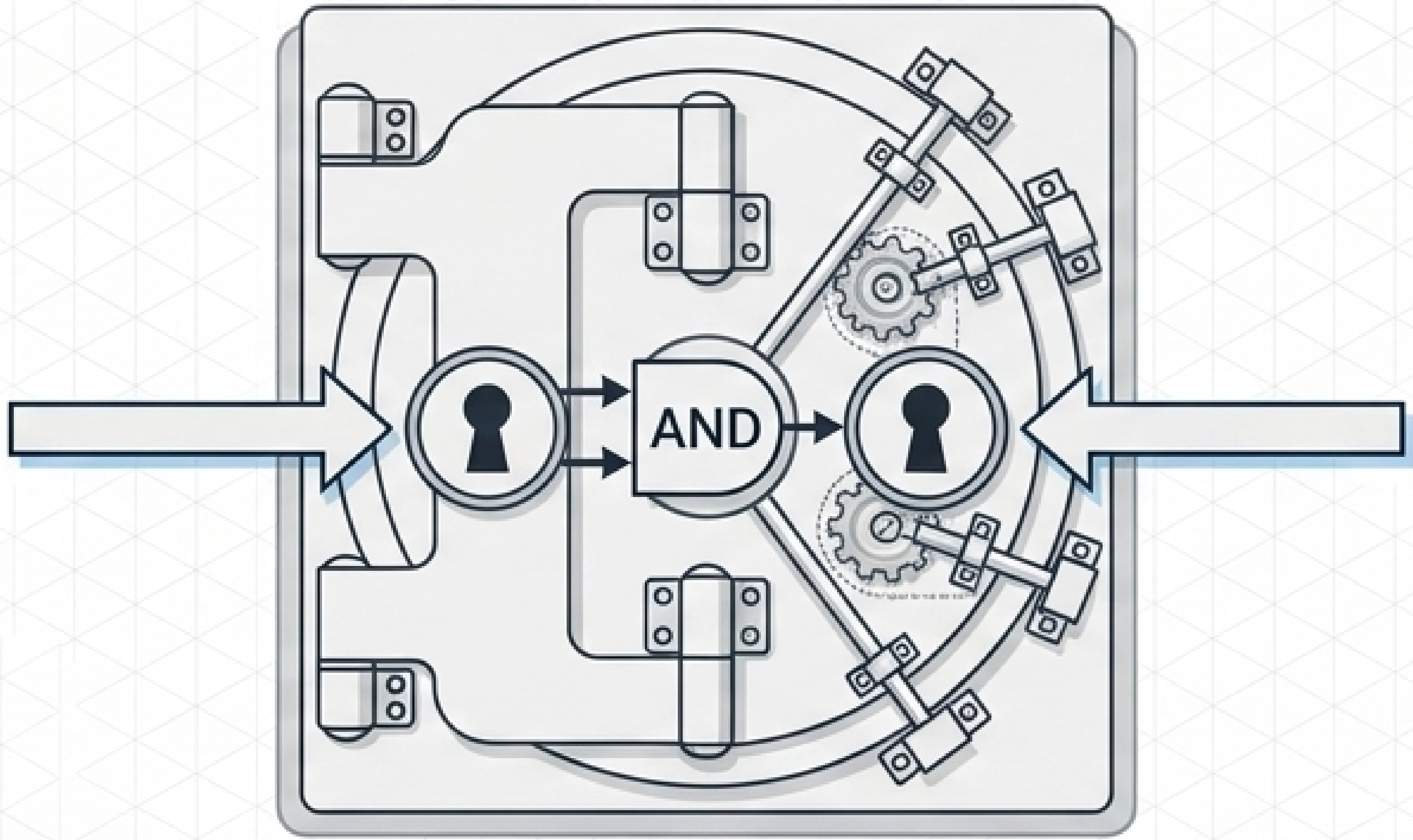
Impact: Zero secrets are stored in the repository, hardcoded in YAML, or persistent on build agents.

NotebookLM

The Dual-Lock Mechanism: Compound Identity

Key 1: The Caller
Must be the authorized App-Core Backend API Managed Identity.

`application_id`



Key 2: The User
Must be a verified human user belonging to a specific Security Principal Group.

`object_id`

The Rule of Compound Auth

Azure Key Vault secrets are only released via the OAuth 2.0 **On-Behalf-Of** (OBO) flow if BOTH conditions are met. This physically prevents rogue applications from scraping raw data, while simultaneously preventing unauthorized internal users from directly querying the vault.

NotebookLM

The Zero-Touch Identity Machine in Action

GitOps Assembly Line

HR/IAM Request

Non-technical admin updates user email and assigns role in `App-Users-Config YAML`

Pull Request

Data pushed to main. Branch policies enforce manual code review.

Pipeline Trigger

Merge natively triggers `01-terraform-provision-appcore-users-pipeline.yaml` in the App-Users engine.

Secretless Auth

Pipeline dynamically authenticates via OIDC federation, bypassing static credentials.

State Lock

Terraform actively acquires the state lock on the `enterprise-devops subscription` to prevent drift.

Provisioning

Entra ID created, RBAC groups assigned, and Compound Identity mapped. Zero portal clicks required.

NotebookLM

Vision 2026: Infrastructure as Code Sovereignty

Identity is no longer a manual administrative task. By fusing declarative YAML schemas with deterministic Terraform orchestration, we guarantee environment parity, automate least privilege, and enforce true Zero-Trust architecture at an enterprise scale.

Reference Architecture: nubenetes/terraform-azure-devops

NotebookLM